Plan del parcial SOC N1 – Caso C23: TalentoRemoto Staffing TI S.A.S.

Ética del Hacking / Ciberseguridad Defensiva · Resumen y plan de trabajo del caso C23

Tu caso: C23 – TalentoRemoto Staffing TI S.A.S.

Perfil: outsourcing de talento TI, 100 % remoto, sin oficina física. Madurez de seguridad baja. **CAPEX ≤ COP 20 M** y **OPEX ≤ COP 1,5 M/mes**.

Inventario (20 equipos, no se puede alterar):

- 10 portátiles Windows 11 (consultores)
- 2 estaciones Windows 11 (administración y RR. HH.)
- 4 portátiles macOS
- 2 portátiles Ubuntu
- 1 servidor Ubuntu en la nube (VPN y gateway)
- 1 Windows Server en la nube (identidad)

Activos críticos: identidades, VPN y portátiles. **Cumplimiento:** Ley 1581 (hojas de vida y datos de los consultores) y confidencialidad con clientes.

Las 3 alertas del caso:

1. Inicio de sesión desde un país inusual (Wazuh / NGFW). Corresponde al PB-04.
2. Infostealer bloqueado (Kaspersky EDR). Corresponde al PB-02.
3. Agente detenido sin ticket asociado (Wazuh). Es un escenario específico de tu caso, con playbook propio.

Particularidades que el docente espera ver resueltas:

- Los agentes reportan por Internet o VPN. Define qué pasa cuando un agente se desconecta y cómo lo detectas.
- Hay equipos macOS. Verifica en la documentación oficial la compatibilidad de los agentes de Wazuh y Kaspersky y documenta el procedimiento.
- Hay servidores en la nube. Incluye la recolección de sus logs y deja claro el límite de responsabilidad con el proveedor.
- Para el NGFW, la cotización puede incluir una opción virtual o en la nube, lo que encaja con tu caso y con el presupuesto bajo.

Reglas que más puntos te pueden costar

- **IA no declarada:** −10 puntos. Declárala en el Anexo I.
- **Contraseñas, llaves o IP públicas reales** en el informe, el video o el repositorio: −5 por incidencia (máx. −10). Usa marcadores como `CAMBIAR_CLAVE` y los rangos 192.0.2.0/24, 198.51.100.0/24 y 203.0.113.0/24.
- **Cotizaciones inventadas o no verificables:** 0 en cotización y posible reporte. Debes pedirlas tú, con fecha, proveedor, vigencia y contacto.
- **Capturas:** deben mostrar fecha, hora, usuario y hostname con tus iniciales o C23. Nombra los archivos como `F02_wazuh_agentes.png`.
- **Entrega tardía:** −10 por día.
- En la sustentación oral no se permite IA y el docente puede pedirte reproducir cualquier paso en vivo.

Plan de 10 días

Día	Actividad
1	Fases 0 y 1: carta de autorización, inventario, riesgos y arquitectura. Enviar ya las solicitudes de cotización del NGFW, porque los proveedores tardan en responder.
2–3	Fase 2: Wazuh (instalación, agentes, FIM, SCA, vulnerabilidades, reglas, active response, dashboards)
4–5	Fase 3: Kaspersky y envío de eventos a Wazuh. Punto de control 1.
6–7	Fase 4: GLPI en la nube con HTTPS, configuración completa y base de conocimiento
8	Fase 5 (NGFW) y Fase 6 (severidades, triage, playbooks)
9	Escalamiento, turnos, SLA, KPIs, tickets de ejemplo y presupuesto

Día	Actividad
10	Informe, repositorio y video. Punto de control 2 y entrega.

Estructura del informe (10 capítulos)

1. Resumen ejecutivo
2. Caso y alcance
3. Arquitectura
4. SIEM Wazuh
5. EDR/XDR Kaspersky
6. GLPI en la nube
7. NGFW
8. Procesos del SOC N1
9. Presupuesto y cronograma
10. Conclusiones

Más referencias en formato APA o IEEE y anexos.

Tickets

Necesitas al menos **6 tickets** (uno por tipo de alerta), con **3 originados en alertas reales** de tu laboratorio. Los simulados deben indicarse como tales. Tus 3 alertas del caso cubren la mitad, y las otras 3 las eliges entre los demás tipos mínimos (fuerza bruta, FIM, USB, etc.).

El video debe mostrar el ciclo completo: alerta en Wazuh → ticket en GLPI → triage con playbook → cierre o escalamiento.

Próximos pasos posibles

- Carta de autorización y matriz de riesgos del caso.
- Diagrama de arquitectura.
- Correo de solicitud de cotizaciones del NGFW.
- Playbooks adaptados a C23.